Listy kontroli dostępu

Sieci IP

Firewall

- Termin firewall odnosi się do:
  - dedykowanego sprzętu komputerowego wraz ze specjalnym oprogramowaniem (ochrona całej sieci)
  - oprogramowania blokującego niepowołany dostęp do komputera (personal firewall)
- Do podstawowych zadań należy
  - filtrowanie połączeń wchodzących i wychodzących
  - odmawianie dostępu żądaniom uznanym za niebezpieczne tj. niezgodnym z przyjętą polityką bezpieczeństwa

Firewall

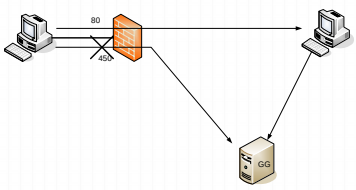
- Oprogramowanie komputerów stacjonarnych:
  - udostępnia wybrane porty do połączeń "z zewnątrz" monitorując ruch
  - udostępnia także połączenia na zewnątrz komputera wybranym usługom/programom
  - Outpost firewall, Sygate Personal Firewall
- Zapory filtrujące:
  - filtrowanie i monitorowanie ruchu (dziennik zdarzeń)
  - PC z systemem Linux (IPtables)
  - Cisco PIX lub router z ACL (lub inne)

Firewall

- Firewall **nie** potrafi ochronić przed:
  - złośliwymi użytkownikami wewnątrz sieci
  - przed połączeniami, które przez niego nie przechodzą
  - przed całkowicie nowymi zagrożeniami
  - przed wirusami (rozpoznanie wirusa w pakiecie przechodzącym przez firewall jest trudne i wymaga:
    a) rozpoznania, że pakiet stanowi część programu
    b) określenia, jak program powinien wyglądać
    c) odkrycia, że zmiana w programie jest spowodowana wirusem
  - raczej zepchnięte na funkcje lokalne
  - nie potrafi się sam skonfigurować (iluzja dobrego skonfigurowania)

Tunelowanie

- Tunel - zestawienie połączenia między dwoma odległymi hostami tak, by stworzyć wrażenie, że są połączone bezpośrednio



Podstawy działania

- Decyzja o przepuszczeniu pakietów lub ich odrzucenia podejmowana jest na podstawie adrsów IP (nadawcy - odbiorcy) – filtrowanie pakietów
- Decyzja o umożliwieniu usłudze sieciowej (korzystającej z TCP lub UDP) podejmowana jest na podstawie numerów portów oraz adresów IP

Podstawy działania

- Translacja adresów/translacja portów
- filtrowanie pakietów
  - adres IP nadawcy i celu
  - protokół
  - port źródłowy i docelowy
  - typ komunikatu ICMP
  - wielkość pakietu (weryfikacja z tą podaną w nagłówku)
  - Liczba pakietów w jednostce czasu
- pośrednik (proxy) – komunikacja z zewnętrznymi serwerami w imieniu wewnętrznych
- VPN – Virtual Private Network – przechodzi przez publiczną, szyfrowanie i ochrona pakietów

Podstawy działania

- Głównym elementem konfiguracji każdego firewalla jest zbiór reguł:
  - Każda z reguł składa się warunku i akcji
  - Reguły stosowane są do każdej jednostki informacji (np. pakietu IP)
  - Reguły przeglądane są w określonym porządku
    - Jeśli warunek pierwszej reguły nie jest spełniony dla tej jednostki informacji, to sprawdzana jest druga reguła itd
    - Jeśli zaś warunek reguły jest spełniony, to do jednostki informacji wykonywana jest odpowiednia akcja zgodnie definicją reguły

Strefa zdemilitaryzowana (DMZ)

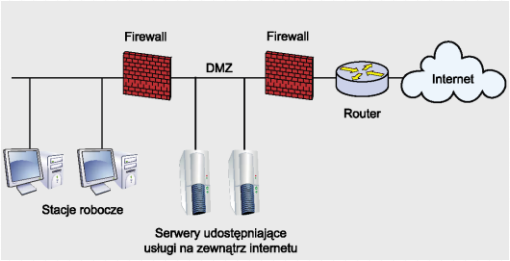
- Strefa ograniczonego zaufania – jest to wydzielany na zaporze sieciowej obszar sieci komputerowej nie należący do sieci wewnętrznej
- Umieszcza w niej się serwery usług wymagające otwarcia na ruch z Internetu
- Usługi dla sieci o obniżonym poziomie zaufania – konieczność wyodrębnienia logicznego lub fizycznego (dedykowany przełącznik lub VLAN)

Strefa zdemilitaryzowana

- Komunikacja pomiędzy siecią LAN (wewnętrzną) a strefą **DMZ**:
  - najbezpieczniej byłoby wyłączyć całkowicie ruch między tymi dwoma strukturami.
  - Nie jest to możliwe (użytkownicy sieci LAN musza mieć dostęp do poczty elektoronicznej)
  - Firewall jest tak konfigurowany aby ruch pomiędzy LAN a DMZ ma charakter jednostronny:
    - połączenie powinno być dopuszczalne tylko wtedy, gdy ruch inicjujący wychodzi z sieci wewnętrznej.
    - całkowicie zabronione powinno być natomiast inicjowanie połączeń z serwera znajdującego się w strefie DMZ.

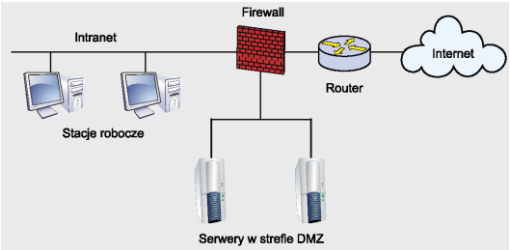
Strefa zdemilitaryzowana

- Stakowanie zapór sieciowych (dual firewall)



Strefa zdemilitaryzowana

- trójostrzowy firewall (Three-pronged firewall)



Porty

- Związane z protokołami transportowymi TCP i UDP używanymi w Internecie do identyfikowania procesów działających na odległych systemach
- Numery portów reprezentowane są przez liczby naturalne z zakresu od 0 do 65535
- od 0 do 1023 numery „ogólnie znane" (*well-known port numbers*) i zarezerwowane dla powszechnie znanych usług, jak:
  - WWW (80 - serwer)
  - 20/21 for FTP
  - 23 for Telnet
- Dzięki temu możemy identyfikować nie tylko procesy, ale ogólnie znane usługi działające na odległych systemach.

Gniazda (sockets)

- Kombinację adresu IP i numeru portu określa się jako gniazdo.
- Umożliwia jednoznaczną identyfikację poszczególnych procesów sieciowych w ramach całego Internetu.
- Zapis ma następującą postać: adres IP:port: 62.96.227.70:80

Grupy portów

- 65 535 różnych portów TCP i UDP.
- Podzielono je na trzy grupy:
  - Porty dobrze znane od 1 do 1023:
    - Upraszcza to budowę połączenia, ponieważ nadawca i odbiorca z góry wiedzą, że dane muszą być przesłane do określonego procesu i do konkretnego portu.
    - Dobrze znane porty umożliwiają klientom łączenie się z serwerami bez konfigurowania
      - 20 FTP – dane, 21 FTP
      - 22 SSH, 23 Telnet
      - 53 DNS, 80 HTTP
      - 110 POP3, 137 NetBIOS Name
      - 143 IMAP, 161 SNMP
      - 179 BGP, 443 HTTPS
    - Do roku 1992 dobrze znane porty zawierały się w obszarze 1 do 255. Numery od 256 do 1023 stosowano do usług uniksowych

Grupy portów

- Porty zarejestrowane (registered ports) to porty od numeru 1024 do 49.151.
  - Przeznaczone są do usług, które zwyczajowo korzystają z określonych portów. Przykładem może być port 3128, często wykorzystywany przez serwery proxy jako alternatywny dla protokołu HTTP.
- Porty przydzielane dynamicznie (dynamically allocated ports, również nazywane ephemeral ports).
  - Przydzielane są zawsze dynamicznie i mają numery od 49.152 do 65.535.
  - Może z nich korzystać dowolny klient, jeśli kombinacja protokołu transportowego, adresu IP i numeru portu jest jednoznaczna.

Co to jest lista kontroli dostępu

ACL

- Router – przekazuje pakiety do kolejnego węzła na ścieżce do przeznaczenia
- **ACL** – uporządkowany zestaw instrukcji akceptujących lub odrzucających pakiety przekazywane przez interfejs zgodnie z kryteriami określonymi przez parametry listy kontroli dostępu i zawartość pakietów

ACL

- Listy kontroli dostępu stosuje się po to aby:
  - Ograniczyć ruch w sieci i zwiększyć wydajność sieci
  - Mieć możliwość kontroli ruchu w sieci
  - Zapewnić podstawowy poziom zabezpieczeń podczas dostępu do sieci – *jeden może inny nie*
  - Mieć możliwość decydowania o typie ruchu przenoszonego lub blokowanego – *TO można a TAMTO jest zabronione*
  - Ograniczyć dostęp do poszczególnych części sieci (*Poszczególni użytkownicy / grupy użytkowników mogą mieć lub nie mieć dostępu do części sieci*)

ACL

- Filtr bazuje na parametrach pakietów:
  - Adres źródłowy
  - Adres docelowy
  - Protokół (TCP, UDP, ICMP, itd.)
  - Numery portów
  - Flagi pakietów
  - Czas
  - Zawartość pakietów
- Przepuść lub zablokuj

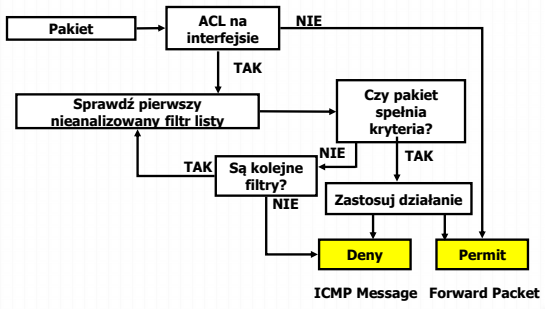
Jak działa router?

- Przekazuje pakiety z interfesjów wejściowych na wyjściowe w oparciu o tablicę rutingu
- Na każdym interfejsie można założyć dwie listy dostępu – po jednym w każdym kierunku
  - IN
  - OUT
- Dla każdego protokołu można założyć oddzielne listy

Jak działa ACL?

- Listy są przeglądane sekwencyjnie
- Dopasowanie pakietu do wpisu daje jednoznaczną decyzję
- Brak dopasowania – odrzucenie
  - (niejawne deny any)

Jak działa router (z listami dostępu)?



Rodzaje list kontroli dostępu

- Standardowe
- Rozszerzone
- Nazywane
- Listy dostępu obsługujące harmonogramy
- Dynamiczne listy dostępu
- Listy zwrotne (refleksyjne)
- Listy bazujące na zawartości pakietu (CBAC, NBAR)

Rodzaje list kontroli dostępu

- Lab_A(config)#**access-list ?**
  - **<1-99> standardowa lista dostępu IP**
  - **<100-199> rozszerzona lista dostępu IP**
  - <1000-1099> lista dostępu IPX SAP
  - <1100-1199> rozszerzona lista dostępu 48-bitowych adresów MAC
  - <1200-1299> lista dostępu adresu skonsolidowanego IPX
  - **<1300-1999> standardowa lista dostępu IP (rozszerzony zakres)**
  - <200-299> lista dostępu typu-kodu protokołu
  - <300-399> lista dostępu DECnet
  - <600-699> lista dostępu Appletalk
  - <700-799> lista dostępu 48-bitowych adresów MAC
  - <800-899> standardowa lista dostępu IPX
  - <900-999> rozszerzona lista dostępu IPX
  - **<2000-2699> rozszerzona lista dostępu IP (rozszerzony zakres)**

Standardowe listy kontroli dostępu

- Numery 1 - 99 oraz 1300-1399
- Filtr bazujący na źródłowych adresach IP
  - Pakiety można pogrupować w zależności od pochodzenia
  - Pakiety pochodzące z danej sieci IP mogą być przepuszczane/blokowane
  - Pakiety pochodzące z zadanego zakresu adresów IP źródłowych mogą być przepuszczane/blokowane

Standardowe listy kontroli dostępu

- Tworzenie ACL

```
Router(config)#access-list access-list-number {permit/deny} {test-conditions}
 [log]

Lab_A(config)#access-list 1 permit 192.5.5.0
 0.0.0.255 log
```

Standardowe listy kontroli dostępu

- Powiązanie ACL z interfejsem w odpowiednim kierunku

```
Router(config-if)#{protocol} access-group
  access-list-number {in/out}
Lab_A(config-if)#ip access-group 1 out
Lab_A(config-if)#ip access-group 2 in
```

Standardowe listy kontroli dostępu

- **access-list**
- **1** – numer definiujący jednocześnie rodzaj ACL
- **deny** (lub permit) – zablokuj / przepuść
- **192.5.5.0** Maska IP (wzorzec adresu)
- **0.0.0.255** Maska blankietowa/Wildcard Mask
- **remark** – komentarz do wpisu
- **log** – wyświetlenie informacji o użyciu filtru (numer ACL, akcję, liczba pakietów)

Maska blankietowa

- Maska blankietowa mówi, które bity w masce (wzorcu) IP muszą się zgadzać, a które są ignorowane podczas sprawdzania dopasowania
  - 0 - wartość na tej pozycji musi się zgadzać
  - 1 - wartość na tej pozycji nie wpływa na dopasowanie
    - 192.5.5.0 0.0.0.255
    - 11000000.00000101.00000101.00000000
    - 00000000.00000000.00000000.11111111

Maska blankietowa

- Maska blankietowa – 32 bity – 0 lub 1
- 0.255.255.255 – cała sieć klasy A
- 0.0.255.255 - cała sieć klasy B
- 0.0.0.255 - cała sieć klasy C
- 0.0.0.0 – dokładnie jeden adres
- 255.255.255.255 – każdy adres
- Wartości pośrednie oraz nieciągłe
  - 0.0.0.31 (00000000.00000000.00000000.00011111)
  - 0.0.0.32 (00000000.00000000.00000000.00100000)

Opcja HOST

- `Lab_A(config)#access-list 2 permit 192.168.10.1 0.0.0.0`
- `Lab-A(config)#access-list 3 permit host 192.168.10.1`

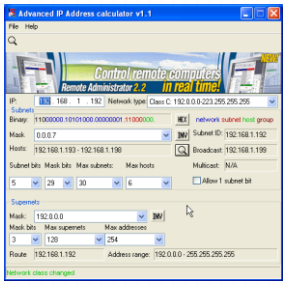
Opcja ANY

- `Lab-A(config)#access-list 4 permit 192.168.10.0 255.255.255.255`
- `Lab-A(config)#access-list 5 permit 0.0.0.0 255.255.255.255`
- `Lab-A(config)#access-list 6 permit any`

Pytanie kontrolne

- Czy do wpisu 192.168.10.3 0.0.0.255 pasują pakiety z adresów:
  a. 192.168.10.255
  b. 192.168.0.0
  c. 192.168.10.2
  d. 10.0.0.255
  e. 150.254.29.66

Maski podsieci i nie tylko



- http://www.radmin.com

ACL jako ciąg filtrów

- Kolejność wpisów ma decydujący wpływ na działanie listy
  - Access-list 7 permit 192.168.10.0 0.0.0.255
  - Access-list 7 permit 192.168.20.0 0.0.0.255
  - Access-list 7 permit 192.168.30.0 0.0.0.255
  - Access-list 7 deny 192.168.10.1 0.0.0.0
  - Access-list 7 deny 192.168.20.1 0.0.0.0
  - Access-list 7 deny 192.168.30.1 0.0.0.0

  Zła kolejność!!!!!!!!!!!!

ACL jako ciąg filtrów

- Access-list 8 deny 192.168.10.1 0.0.0.0
- Access-list 8 deny 192.168.20.1 0.0.0.0
- Access-list 8 deny 192.168.30.1 0.0.0.0
- Access-list 8 permit 192.168.10.0 0.0.0.255
- Access-list 8 permit 192.168.20.0 0.0.0.255
- Access-list 8 permit 192.168.30.0 0.0.0.255

DOBRZE!

ACL jako ciąg filtrów

- Przedstawiona lista kontroli dostępu przepuszcza adresy z zakresu 1.0.0.2 do 1.0.0.100 – pozostałe blokowkuje:
  - Access-list 11 deny host 1.0.0.1
  - Access-list 11 permit 1.0.0.0 0.0.0.63
  - Access-list 11 permit 1.0.0.64 0.0.0.31
  - Access-list 11 permit 1.0.0.96 0.0.0.3
  - Access-list 11 permit 1.0.0.100 0.0.0.0

Niejawne „deny any”

- Lista ACL to kilka filtrów
- Decyzja o przekazaniu/porzuceniu pakiety jest podejmowana na podstawie pierwszego wpisu, który pasuje do analizowanego pakietu
- Jeśli pakiet nie pasuje do żadnego wpisu jest on **porzucany (deny)**
- Ten mechanizm jest znany jako **„niejawne deny any”**

Położenie standardowych ACL

- Jedyny parametr – adres źródłowy pakietu
- Należy je umieszczać najbliżej docelowych adresów

Rozszerzone listy kontroli dostępu

- Numery 100 - 199 oraz 2000-2199
- Bardziej precyzyjny (złożony) filtr:
  - Adres źródłowy
  - Adres przeznaczenia
  - Protokół IP (ICMP, TCP, IGRP)
  - Protokół wyższych warstw (http, ftp telnet)
  - Numery portów TCP/UDP

Tworzenie i użycie rozszerzonych ACL

- `Router(config)# access-list` *`access-list-number`* `{permit|deny}` *`{protocol|protocol-keyword} {source source-wildcard} {destination destination-wildcard} [protocol-specific options]`* `[log]`
- `Lab_A(config)#access-list 101 deny tcp 192.168.10.0 0.0.0.255 210.93.105.0 0.0.0.255 eq telnet log`

Tworzenie i użycie rozszerzonych ACL

- `Router(config-if)#{protocol}` **`access-group`** *`access-list-number`* **`{in/out}`**
- `Lab_A(config-if)#`**`ip access-group 101 in`**

Rozszerzone ACL – Protokoły

- IP
- TCP
- UDP
- ICMP
- OSPF, BGP,
- IGRP/EIGRP
- GRE (protokół tunelujący)

Rozszerzone ACL – IP

- access-list 101 deny ip 10.10.0.0 0.0.255.255 150.250.150.0 0.0.0.255
- access-list 101 permit ip 10.30.0.0 0.0.255.255 150.250.150.0 0.0.0.255
- access-list 101 permit ip 10.40.0.0 0.0.255.255 any
- access-list 101 permit ip host 10.0.0.1 any

Rozszerzone ACL – porty TCP/UDP

- Rozszerzone ACL oferują pewne dodatkowe testy
  - Dla protokołów TCP i UDP dostępne są słowa kluczowe sprawdzające port:
    - **`eq X`** (equal) port źródłowy lub docelowy równy X
    - **`gt X`** (greater than) port źródłowy lub docelowy większy niż X
    - **`lt X`** (lower than) port źródłowy lub docelowy mniejszy niż X
    - **`range X Y`** zakres portów źródłowych lub docelowych od X do Y

Rozszerzone ACL – porty TCP/UDP

- access-list 102 permit tcp 10.40.0.0 0.0.255.255 any eq 80
- access-list 102 permit tcp 10.40.0.0 0.0.255.255 gt 1023 any
- access-list 102 permit udp 10.40.0.0 0.0.255.255 any eq 53

Rozszerzone ACL – flagi TCP

- **`syn`** pakiet inicjujący połączenie
  - deny tcp any gt 1023 host 169.254.10.1 eq 25 syn
- **`ack`** większość pakietów w strumieniu TCP
- **`established`** ustawiona flagą ACK, ale zgaszona flaga SYN, RST lub FIN - czyli pakiety „ze środka połączenia”
- **`rst`**

Rozszerzone ACL – flagi TCP

- access-list 102 permit tcp any gt 1023 any established

Rozszerzone ACL – ICMP

Lab_C(config)#access-list 101 permit icmp any any ?

```
<0-255>                      ICMP message type
administratively-prohibited  Administratively prohibited
alternate-address            Alternate address
conversion-error             Datagram conversion
dod-host-prohibited          Host prohibited
dod-net-prohibited           Net prohibited
dscp                         Match packets with given dscp value
echo                         Echo (ping)
echo-reply                   Echo reply
fragments                    Check non-initial fragments
general-parameter-problem    Parameter problem
host-isolated                Host isolated
host-precedence-unreachable  Host unreachable for precedence
host-redirect                Host redirect
host-tos-redirect            Host redirect for TOS
host-tos-unreachable         Host unreachable for TOS
```

Rozszerzone ACL – ICMP

- 0 – Echo Reply
- 8 – Echo request

Można stworzyć taką ACL, która sprawi, ze my będziemy mogli „pingować”, a nas nie „spingują”

JAK? – na odpowiednim kierunku przepuszczamy Echo request, a blokujemy echo replay, na przeciwnym kierunku odwrotnie

Rozszerzone ACL – ICMP

- access-list 101 permit icmp any any echo
- access-list 102 permit icmp any any echo-reply

- interface s0
- ip access-group out 101
- ip access-group in 102

- no ip unreachable (zapobbiega wysyłaniu wiadomości ICMP – sieć nieosiągalna)

Nazywane ACL

```
Router#configure terminal
Router (config)#ip access-list standard
 lista_moja_1
Router (config-std-nacl)#permit host
 192.168.10.1
Router (config-std-nacl)#int s1
Router (config-if)#ip access-group lista_moja_1
 out
```

Nazywane ACL

```
Router#configure terminal
Router (config)#ip access-list extended
 lista_moja_2
Router (config-ext-nacl)#permit tcp any host
 10.0.0.1 eq www
Router (config-ext-nacl)#int s1
Router (config-if)#ip access-group
 lista_moja_2 out
```

Położenie ACL

- Dla każdego protokołu i w każdym kierunku można użyć jednej listy dostępowej na każdym interfejsie
- Standardowe listy dostępowe należy umieszczać możliwie najbliżej miejsca docelowego
- Rozszerzone listy dostępowe należy umieszczać możliwie najbliżej miejsca źródłowego

Praca z listami kontroli dostępu

- Tworzenie – **acces-list .....**
- Zakładanie ACLi na interfejs IP – **ip acces-group...**
- Kasowanie **całej listy – no acces-list xx**
  - Lub no access-list standard moja_lista
- Zdejmowanie listy z interfejsu – **no ip access-group in/out**

Edycja ACL

- Nie należy pracować na aktywnej liście
- Usuwając listę dostępową, należy zachować ostrożność.
  - Jeśli usunięto listę, która działa na aktywnym interfejsie, w odniesieniu do interfejsu może zostać zastosowana domyślna instrukcja „deny any" i cały ruch na tym interfejsie zostanie zatrzymany.
  - Jeśli ustawieniem domyślnym systemu IOS jest „permit any", zlikwidowana zostanie ochrona i regulacja wydajności

Edycja ACL

- Nowe wpisy są zawsze dodawane na końcu listy dostępowej.
- Aby pokonać tę niedogodność:
  - Wyedytuj (stwórz) plik tekstowy o strukturze jak poniżej:
    - No access-list 10
    - Access-list 10 permit 10.0.0.0 0.0.0.255
    - Access-list 10 permit 20.0.0.0 0.0.0.255
  - W odpowiednim trybie wydaj polecenie
    - Config network i wskaż plik przez tftp

Edycja ACL

- Filtry wychodzące nie wpływają na ruch, którego źródłem jest lokalny router.
- Należy zwracać uwagę, aby filtry dotyczyły takiego ruchu jaki ma szanse się pojawić na analizowanych interfejsach i w odpowiednich kierunkach

Analiza działania ACL

- Router# **clear access-list counters** [ACL_#_or_name]
- Show access-lists 101

ACL na telnet do routera

- Aby telnet do naszego routera był możliwy tylko z zaufanych hostów:
  - Tworzymy listę (przykładową)
    - R(config)#**access-list 2 permit 172.16.1.0 0.0.0.255**
      R(config)#**access-list 2 permit 172.16.2.0 0.0.0.255**
      R(config)#**access-list 2 deny any**
  - Kojarzymy ją ze zdalnym dostępem do routera:
    - R(config)#**line vty 0 4**
      R(config-line)#**login**
      R(config-line)#**password** *secret*
      R(config-line)#**access-class 2 in**

ACL na telnet do routera

- Aby z naszego routera możliwe było wywołanie telnetu na tylko na wskazane routery należy:

```
Rtr1(config)access-list 3 permit 10.0.0.0 0.0.0.255
Rtr1(config)#line vty 0 4
Rtr1(config-line)#access-class 3 out
```

ACL na telnet do routera

- Aby z naszego routera niemożliwe było wywołanie telnetu na inny router należy:

```
Rtr1(config)access-list 3 deny any
Rtr1(config)#line vty 0 4
Rtr1(config-line)#access-class 3 out
```

- To samo,ale inaczej:

```
Rtr1(config-line)# transport output none
```

Hasła dostępu do routera:

- Podejście konwencjonalne:

```
line con 0
password cisco1
login
line aux 0
password cisco2
login
line vty 0 4
password cisco3
login
end
```

Telnet i użytkownicy

- Użytkownicy i ich hasła:
  - R(config)# username u_1 password h_1
  - R(config)# username u_2 password h_2
  - R(config)# aaa new-model
  - R(config)# aaa authentication login moje local
  - R(config)#aaa authentication password-prompt podaj_haslo
  - R(config)#aaa authenticatio username-prompt podaj_nazwe
  - R(config)# line vty 0 4
  - R(config-line)# login authentication moje

Limitowany dostęp przez HTTP

- Ograniczanie dostępu do routera przez przeglądarkę www:

```
R(config)#ip http server
R(config)#access-list 99 permit 192.168.0.1
R(config)#access-list 99 permit 192.168.5.0 0.0.0.31
R(config)#access-list 99 permit 192.168.45.0
0.0.0.255
R(config)#ip http access-class 99
R(config)#ip http authentication enable
```

- Jeśli nasze ACL zablokują zbyt dużo, możemy stracić ważną funkcjonalność komunikacji:
- RIP przesyła UDP na port 520 do sąsiadów
- Aby przepuścić IGRP:
  - IGRP - Access-list 101 permit IGRP 192.168.10.0 0.0.0.255 host 192.168.10.1
- EIGRP (ma własny typ protokołu IP) wykorzystuje rozgłoszenia grupowe (typu Hello) oraz do zdefiniowanych sąsiadów:
  - Access list 101 permit eigrp src host 224.0.0.10
  - Access list 101 permit eigrp src host 192.168.10.1

- OSPF (ma własny typ protokołu IP) i wykorzystuje rozgłoszenia grupowe (typu Hello) oraz do zdefiniowanych sąsiadów:
  - Access list 101 permit ospf src host 224.0.0.4
  - Access list 101 permit ospf src host 192.168.10.1
- Także protokół BGP na swój protokół IP

Weryfikacja ACL

- **show ip interface**
- **show access-lists**
- **show running-config**
- **show log**
- **clear access-list counters**
- Ograniczanie „**debug ip packet**”
  - R(config)#access-list 98 permit 192.168.0.0 0.0.0.255
  - R#debug ip packet 98

Optymalizacja

- **`show access-lists`** pokaże nie tylko budowę ACL, ale również ilość pakietów wychwyconych przez poszczególne wpisy
- Lista jest przeglądana dopóki router znajdzie pasujący filtr – należy zadbać, aby najwięcej wpisów miały filtry umieszczone na początku
- **Należy pamiętać o kolejności szczegółów!!**
- Przemyśleć kolejność wpisów zarówno pod kątem rosnącej szczegółowości jaki i częstości dopasowania

Optymalizacja

- Należy grupować wpisy
  - Zamiast 128 hostów po kolei
  - Wpisać cały zakres
- Nie warto podwójnie filtrować tego samego ruchu na obu interfejsach (to co zostanie odrzucone na wejściu nie pojawi się na wyjściu i nie powinno trafić do wyjścia)

Optymalizacja

- Jeśli chcemy możemy odrzucić ruch do całych sieci:
  - deny ip 10.0.0.0 0.255.255.255 any
- Ale z punktu wydajności routera lepiej:
  - Stworzyć interfejs
    - interface null0
    - description Interfejs pochłaniający niechciane pakiety
    - no ip unreachables ! (Żeby to było po cichu)
  - Przekierować przez statyczny routing niechciany ruch:
    - ip route 10.0.0.0 255.0.0.0 null 0

Listy dostępu obsługujące harmonogramy

Listy dostępu obsługujące harmonogramy

- Pozwalają na kontrolowanie dostępu do zasobów sieciowych w sposób zależny od dnia tygodnia lub godziny.
- Można zdefiniować różne zasady bezpieczeństwa obowiązujące w godzinach pracy firmy, inne po godzinach, a jeszcze inne w dni wolne od pracy
- Różne polityki bezpieczeństwa będą wdrażane samoczynnie

Harmonogramy - tworzenie

1. Zadefiniowanie nazwy zakresu czasowego
   Router(config)#time-range nazwa_zakresu
2. Konfiguracja zakresu czasowego
   - **absolute** - wskazuje jednorazowy okres – określany przez początek i koniec okresu
     - Lab_C(config-time-range)#absolute start 10:00 10 october 2005
     - Lab_C(config-time-range)#absolute end 20:00 10 october 2005
   - **periodic** - wskazuje okres powtarzalny - określany przez początek i koniec zakresu czasowego

Harmonogramy - tworzenie

- **Lab_C(config-time-range)#periodic ?**

```
Friday      Friday
Monday      Monday
Saturday    Saturday
Sunday      Sunday
Thursday    Thursday
Tuesday     Tuesday
Wednesday   Wednesday
daily       Every day of the week
weekdays    Monday thru Friday
weekend     Saturday and Sunday
```

Harmonogramy - tworzenie

- **Lab_C(config-time-range)#periodic mon ?**

```
Friday      Friday
Saturday    Saturday
Sunday      Sunday
Thursday    Thursday
Tuesday     Tuesday
Wednesday   Wednesday
hh:mm       Starting time
```

- **Lab_C(config-time-range)#periodic monday 8:00 to friday 16:00**

Harmonogramy - tworzenie

- Jak zabronić pracownikom firmy surfowania www w czasie pracy?
  - Router(config)#**time-range NoHTTP**
  - Router(config-time-range)#**periodic weekdays 8:00 to 18:00**
  - Router(config-time-range)#**exit**
  - Router(config)#**ip access-list extended teraz_praca**
  - Router(config-ext-nacl)#**deny tcp any any eq www time-range NoHTTP**
  - Router(config-ext-nacl)#**permit ip any any**

Dynamiczne listy dostępu

Dynamiczne listy dostępu

- W dynamicznych listach dostępu router tworzy specyficzne wpisy w odpowiedzi na udaną procedurę uwierzytelniania użytkownika:
  - użytkownik nawiązuje sesję protokołu telnet i w celu uwierzytelnienia podaje swój identyfikator i hasło.
  - Po uwierzytelnieniu router umieszcza dynamiczny wpis na liście dostępu
  - Od tego momentu (przez jakiś czas) router akceptuje pakiety zawierające adres źródłowy protokołu IP uwierzytelnionego hosta.

Dynamiczne listy dostępu

- Rozwiązanie to jest bardzo wygodne dla użytkowników nawiązujących połączenie poprzez usługodawcę internetowego - który za każdym razem przypisuje im inne adresy protokołu IP.
- Stworzenie wpisu na zwykłej liście dostępu pozwalającego routerowi na akceptowanie pakietów pochodzących od tych właśnie użytkowników byłoby trudne.
- Jest to mechanizm „otwierania sieci" dla autoryzowanych użytkowników.

Tworzenie dynamicznych list dostępu

- #access-list
  - numer_listy_dostępu
  - dynamic nazwa
  - timeout czas
  - permit|deny
  - protokół
  - Źródłowe_IP źródłowa_maska_wieloznaczna
  - docelowe_IP docelowa_maska_wieloznaczna

Tworzenie dynamicznych list dostępu

- Wpis dynamiczny jest częścią rozszerzonej listy dostępu, pozostałe wpisy dodawane są tak samo jak instrukcje rozszerzonej listy dostępu
- Aby go utworzyć:
  - Router(config)#username user password pass
  - Router(config)#line vty 0 4
  - Router(config-line)#login local
  - Router(config-line)#autocommand access-enable host timeout 5

Wykorzystanie

- **Stan routera przed uwierzytelnieniem:**

```
Lab_C#sh ip access-lists
Extended IP access list 101
    Dynamic moja_dynamiczna permit icmp any any
    permit tcp any any eq telnet
```

- **Stan routera po uwierzytelnieniu:**

```
Lab_C#sh ip access-lists
Extended IP access list 101
    Dynamic moja_dynamiczna permit icmp any any
        permit icmp host 172.18.0.2 any (132 matches) (time left 299)
    permit tcp any any eq telnet (297 matches)
```

Wykorzystanie

- Należy pamiętać, aby „normalnie” wpuścić telnet do routera z dynamiczną listą
- Po poprawnym uwierzytelnieniu router samoczynnie zamyka sesję telnet
- Ponowne zestawienie zaowocuje komunikatem:
  - List#101-moja_dynamiczna already contains this IP address pair

Wykorzystanie

- Jeśli linie 0 – 4 vty zostaną skonfigurowane tak samo, to wszystkie odbierane żądania dotyczące sesji telnet będą traktowane przez router jako próby otwarcia dynamicznego wpisu listy dostępu, wówczas administrator nie będzie mógł zarządzać routerem za pomocą tego protokołu.
- Aby to zmienić należy skonfigurować linie 0 -2 normalnie natomiast linie 3-4 portu vty w następujący sposób:
  - Router(config)#**line vty 3 4**
  - Router(config-line)#**login local**
  - Router(config-line)#**rotary 1**
    - Polecenie **rotary 1** umożliwia uzyskanie dostępu do routera w normalnej sesji protokołu telnet z wykorzystaniem portu 3001.
    - **telnet a.a.a.a 3001**
    - Pamiętaj, aby dla sesji 3 i 4 usunąć „autocommand..... „

Listy zwrotne (refleksyjne)

Refleksyjne ACL

- Pozwalają na zwiększenie bezpieczeństwa sieci poprzez dodatkowy mechanizm filtrowania pakietów.
- Filtr zapamiętuje pakiety wychodzące a następnie pozwala na zwrotne odesłanie wyłącznie pakietów stanowiących odpowiedź.
- Router automatycznie tworzy reguły filtrowania na komplementarnym kierunku w taki sposób, by automatycznie przyjmować pakiety powrotne.
- Pakiet jest traktowany jako odpowiedź jeżeli adresy i port pochodzenia i adres i port przeznaczenia odpowiadają wartościom zapamiętanym.
- Mechanizm ten może zostać z powodzeniem wykorzystany w routerach stanowiących część systemów firewall.

Tworzymy refleksyjne ACL

- Muszą to być rozszerzone listy nazwane
- Słowem kluczowym jest *reflect*
- Każda instrukcja oznaczona jako *reflect* posłuży do utworzenia „lustrzanej” reguły w komplementarnej liście (na przeciwnym kierunku)
- Lustrzane wpisy mają skończony czas życia
  (limit czasu bezczynności)
  - R(config)#ip reflexive-list timeout 60
- Wpis znika, gdy wygaśnie time-out lub sesja zostanie zamknięta (TCP – flaga RST/FIN)

Tworzymy refleksyjne ACL

- R(config)#ip access-list extended *ref_out*
- R(config-ext-nacl)#permit ip 150.254.0.0 0.0.255.255 any reflect moja33 timeout 30

- R(config)#ip access-list extended *ref_in*
- R(config-ext-nacl)#evaluate moja33

Zastosowanie

- Uwaga – kolejność wpisów jak najbardziej nadal jest istotna
- Co się stanie w poniższym przypadku:
  - ip access-list extend wyjscie
  - permit ip any any
  - permit tcp any any reflect moje
  - permit udp any any reflect moje
  - permit icmp any any reflect moje
- Czy lustrzane wpisy listy moje zostaną utworzone? Dlaczego?

Wykorzystujemy refleksyjne ACL

- Refleksyjnymi listami zapewniamy sobie w wygodny sposób, że połączenia będą inicjowane tylko z wewnątrz naszej sieci (lub innych zaufanych sieci)
- A co w przypadku FTP?
  - Na port 21 zestawiane jest połączenie sterujące od klienta do serwera
  - Serwer wysyłając dane zestawia połączenie z portu 20 do klienta.
  - Takie połączenie nie przejdzie.
  - Na szczęście FTP może działać w trybie pasywnym
    - W takim przypadku klient na żądanie/wskazanie serwera zestawia połączenie
- Jednak zwrotne listy źle będą wpływać na działanie aplikacji wykorzystujących nietypowe połączenia TCP (inicjowane na żądanie itp.)

Wykorzystujemy refleksyjne ACL– ćwiczenie 1

- Zabezpiecz router dostępowy tak, aby:
  - Użytkownicy mogli korzystać z http (również https)
  - Hosty spoza naszej sieci nie powinny mieć możliwości samodzielnie przesyłać do nas żadnych informacji

Wykorzystujemy refleksyjne ACL – rozwiązanie 1

```
ip access-list extend wyj
permit tcp any any eq 80 reflect moje
permit tcp any any eq 443 reflect moje
permit udp any any eq 53 reflect moje
permit tcp any any eq 23 reflect moje
ip access-list extend wej
evaluate moje

int serial 0
ip access-group wyj out
ip access-group wej in
```

Za dużo?

```
I   192.168.8.0/24 is possibly down, routing via 192.168.4.2, Serial0/1
I   192.168.9.0/24 is possibly down, routing via 192.168.4.2, Serial0/1
I   192.168.10.0/24 is possibly down, routing via 192.168.4.2, Serial0/
I   172.17.0.0/16 is possibly down, routing via 192.168.2.1, Serial0/0
I   172.19.0.0/16 is possibly down, routing via 192.168.4.2, Serial0/1
C   172.18.0.0/16 is directly connected, Ethernet0/0
I   172.21.0.0/16 is possibly down, routing via 192.168.4.2, Serial0/1
I   172.20.0.0/16 is possibly down, routing via 192.168.4.2, Serial0/1
I   172.23.0.0/16 is possibly down, routing via 192.168.4.2, Serial0/1
I   172.22.0.0/16 is possibly down, routing via 192.168.4.2, Serial0/1
C   192.168.4.0/24 is directly connected, Serial0/1
I   192.168.5.0/24 is possibly down, routing via 192.168.4.2, Serial0/1
I   10.0.0.0/8 is possibly down, routing via 192.168.4.2, Serial0/1
I   192.168.6.0/24 is possibly down, routing via 192.168.4.2, Serial0/1
I   192.168.7.0/24 is possibly down, routing via 192.168.4.2, Serial0/1
I   192.168.0.0/24 is possibly down, routing via 192.168.4.2, Serial0/1
I   192.168.1.0/24 is possibly down, routing via 192.168.4.2, Serial0/1
C   192.168.2.0/24 is directly connected, Serial0/0
I   192.168.3.0/24 is possibly down, routing via 192.168.2.1, Serial0/0
```

Wykorzystujemy refleksyjne ACL – rozwiązanie 1

```
Lab_C#sh access-lists
Reflexive IP access list moje
Extended IP access list wej
    evaluate moje
Extended IP access list wyj
    permit tcp any any eq www reflect moje
    permit tcp any any eq 443 reflect moje
    permit udp any any eq domain reflect moje
```

CBAC

mechanizm kontroli dostępu oparty na zawartości

97

CBAC - mechanizm kontroli dostępu oparty na zawartości

- CBAC (Context-Based Access Control) funkcjonuje podobnie do zwrotnych list dostępu - kontrolowane są sesje wyjściowe, a tymczasowe bramy w zaporze sieciowej są tworzone w celu przekazania zwrotnego ruchu sieciowego.
- Zwrotne listy dostępu nie obsługują dobrze protokołów aplikacji, które zmieniają numery portów TCP i UDP podczas sesji.
- CBAC rozpoznaje popularne protokoły oraz aplikacje i umożliwia im utrzymanie połączenia po zmianie portu
- Ponadto CBAC śledzi numery sekwencyjne i pilnuje ich poprawności (zakres, kolejność itp.)

98

CBAC - mechanizm kontroli dostępu oparty na zawartości

- CBAC monitoruje zawartość pakietów do warstwy aplikacji
- CBAC monitoruje wyjściowe sesje FTP i zezwala w razie potrzeby na zestawienie połączenia ze strony serwera w celu przesłania danych.

99

CBAC - mechanizm kontroli dostępu oparty na zawartości

- Monitorowanie sesji przez CBAC:
  - Mechanizmy CBAC analizują tylko to, co przejdzie przez ACL na analizowanym interfejsie
  - CBAC analizuje pakiet TCP i wyniki pamięta w odpowiedniej tabeli (show inspect session detail)
    - Są to podstawowe parametru źródłowe i docelowe ip oraz porty
  - Tworzone są tymczasowe bramy dla ruchu zwrotnego
  - Tymczasowa brama może zostać zamknięta po upływie czasu bezczynności lub prawidłowej wymianie segmentów z flagami FIN

100

CBAC - mechanizm kontroli dostępu oparty na zawartości

- Do prawidłowego działania CBAC są wykorzystywane dwie ACL
  - Lista określająca pakiety, które będą poddawane inspekcji
  - Lista zawierająca tworzone przez CBAC wpisy

101

Główne etapy monitorowania sesji przez mechanizm CBAC:

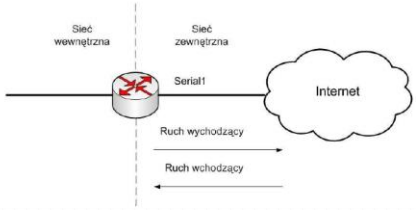
- Pakiet dociera do interfejsu routera i jest analizowany przy użyciu listy dostępu zastosowanej na danym interfejsie (lista powinna akceptować pakiety które mają być później poddane kontroli mechanizmu CBAC)
- CBAC sprawdza pakiet i zapisuje informacje na jego temat w tabeli. Informacje te można wyświetlić stosując polecenie
  - #show ip inspect session detail
- Na danym interfejsie tworzone są tymczasowe bramy na liście dostępu, przeznaczone dla zwrotnego ruch sieciowego
- Pakiet zwrotny po dotarciu do interfejsu routera jest akceptowany zgodnie z tymczasowymi wpisami na liście dostępu i analizowany przez mechanizm CBAC
- Po zakończeniu połączenia odpowiednie wpisy na liście dostępu i w tabeli stanu są usuwane

102

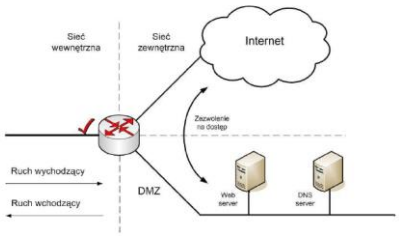
Konfiguracja CBAC

- Określamy protokoły które mają podlegać kontroli oraz interfejs i kierunek na którym ta kontrola ma się rozpocząć
  - Wybór interfejsu dla którego zastanie skonfigurowany mechanizm CBAC
    - Wybierając interfejs zewnętrzny (ta strona z której nie pochodzą sesje) zapobiegamy wejściu określonego ruchu na router ściany ogniowej oraz do wewnętrznej sieci
    - Wybierając interfejs wewnętrzny umożliwiamy zewnętrznemu ruchowi na dostęp do strefy DMZ (np zawierającej serwer http) bez konieczności przejścia przez filtr uniemożliwiając jednocześnie wejście pakietów z sesji, która nie została zainicjowana wewnątrz chronionej sieci.

CBAC na interfejsie zewnętrznym



CBAC na interfejsie wewnętrznym



Konfiguracja CBAC (c.d.)

- Utworzenie listy dostępu dla wybranego interfejsu.
- Zdefiniowanie limitu czasu i wartości progowej
  - CBAC wykorzystuje zakresy czasu i progi aby określić jak długo ma zarządzać informacjami na temat danej sesji oraz kiedy odrzucić sesję nieustanowioną do końca.
  - Domyślnie do poleceń przypisane są pewne wartości, które można zmienić by bardziej odpowiadały naszym wymogom bezpieczeństwa (np. domyślny limit czasu bezczynności dla protokołu TCP wynosi 3600 s)
- Zdefiniowanie reguł inspekcyjnych
  - **#ip inspect name** *nazwa_inspekcji protokół* **alert on|off audit trail on|off timeout** *liczba_sekund*

CBAC - przykład definiowanie reguł inspekcyjnych:

- Router(config)#**ip inspect name** firewall_1 **smtp audit-trail on timeout 60**
  - **Alert -** Mechanizm CBAC może wysyłać komunikaty do serwera obsługującego dziennik systemowy lub buforu routera w przypadku wykrycia nieprawidłowości w monitorowanej aplikacji
  - **audit-trail -** Umożliwia śledzenie i rejestrowanie w dziennikach informacji o połączeniach używanych przez chronione aplikacje

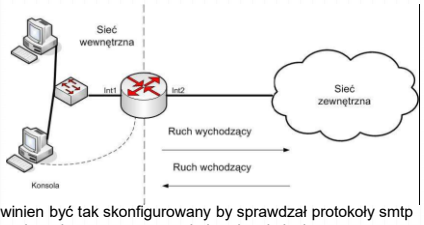
Konfiguracja CBAC (c.d.)

- Przypisanie reguł inspekcyjnych do interfejsów
  - Reguły inspekcyjne powinny być stosowane w kierunku wyjściowego ruchu sieciowego
    - Dla interfejsu wewnętrznego - reguły inspekcyjne na wejściu interfejsu
    - Dla interfejsu zewnętrznego - reguły inspekcyjne na wyjściu interfejsu
- Składnia reguł inspekcyjnych:
  - Router(config-if)#**ip inspect** nazwa_inspekcji **in|out**

Sprawdzenie działania CBAC

- **#debug ip inspect** protokół
- **#show ip inspect session** [detail]
  - Polecenie wyświetla informacje dotyczące tabeli stanu mechanizmu CBAC
- **#show ip inspect config**
  - Polecenie to wyświetla wszystkie specyficzne elementy konfiguracji
- **#show ip inspect interfaces**
  - Polecenie to wyświetla interfejsy dla których skonfigurowano inspekcje CBAC
- **#show ip inspect name** *nazwa_inspekcji*
  - Wyświetla protokoły poddawane inspekcji
- **#show ip inspect all**
  - Prezentuje całą konfigurację CBAC oraz wszystkie istniejące sesje które są aktualnie śledzone i sprawdzane

CBAC – przykład 1



- CBAC powinien być tak skonfigurowany by sprawdzał protokoły smtp oraz tftp przybywające z wewnętrznej chronionej sieci z routera o dwóch interfejsach - int1 jest w chronionej sieci a int2 w niechronionej .
- Listy dostępu powinny być tak skonstruowane by ograniczyć wpływający do niechronionego interfejsu ruch z protokołów ICMP, TCP i UDP.

CBAC – przykład 1

1. Sprawdź za pomocą polecenia ping połączenia z routerem w sieci skonfigurowanej zgodnie z mapą sieci
2. Stwórz listę blokująca wybrane pakiety
3. Przypisz listę do interfejsu
4. Stwórz reguły inspekcji i przypisz je do interfejsu
5. Zweryfikuj poprawność działania listy

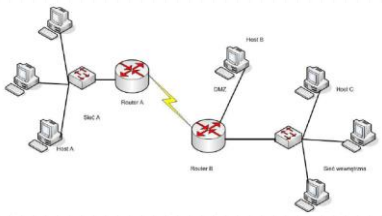
CBAC – przykład 1

- Blokada ruchu typu T CP i U DP pochodzących z dowolnego źródła, zezwolenie na pewien ruch ICMP:
  - Router(config)# **access-list 100 deny tcp any any**
  - Router(config)# **access-list 100 deny udp any any**
  - Router(config)# **access-list 100 permit icmp any any echo-reply**
  - Router(config)# **access-list 100 permit icmp any any time-exceeded**
  - Router(config)# **access-list 100 permit icmp any any packet-too-big**
  - Router(config)# **access-list 100 permit icmp any any traceroute**
  - Router(config)# **access-list 100 permit icmp any any unreachable**
  - Router(config)# **access-list 100 deny ip any any**
- Lista powinna zostać przypisana do interfejsu2 by zablokować dostęp z sieci niechronionej do chronionej
  - Router(config)# **interface** *typ_int2*
  - Router(config-if)# **ip access-group 100 in**

CBAC – przykład 1

- Stworzenie reguł inspekcji
  - Router(config)# **ip inspect name** *nazwa1* **tftp**
  - Router(config)# **ip inspect name** *nazwa1* **smtp**
- Reguła ta musi zostać przypisana do interfejsu 1 w chronionej sieci by kontrolować ruch z niej pochodzący. Kiedy CBAC wykryje ruch typu smtp lub tftp zainicjowany w wewnętrznej sieci, mechanizm stworzy tymczasowe wpisy na liście dostępu pozwalające na ruch powrotny z tych sesji.
  - Router(config)# **interface** *typ_int1*
  - Router(config-if)# **ip inspect** *nazwa1* **in**

CBAC – przykład 2



- Router B jest routerem granicznym na którym trzeba zaimplementować wytrzymałą ścianę ogniową, by zabezpieczyć wewnętrzną sieć w taki sposób aby zewnętrzne hosty nie mogły zapoczątkować sesji z hostami wewnętrznymi.

CBAC – przykład 2

1. Stwórz listę blokująca lub przepuszczającą wybrane pakiety
2. Przypisz listę do interfejsu
3. Stwórz reguły inspekcji i przypisz je do interfejsu
4. Zweryfikuj poprawność działania listy

CBAC – przykład 2

- Konfiguracja CBAC

```
RouterB(config)#ip inspect name firewall_2 ftp
RouterB(config)#ip inspect name firewall_2 tftp
RouterB(config)#ip inspect name firewall_2 udp
RouterB(config)#ip inspect name firewall_2 tcp
RouterB(config)#ip inspect dns-timeout 15
RouterB(config)#ip inspect udp idle-time 1800
```

- Zastosowanie listy na odpowiednich interfejsach

```
RouterB(config)#interface interfejs1
RouterB(config-if)#ip inspect firewall_2 in
RouterB(config)#interface serial2
RouterB(config-if)#ip inspect firewall_2 in
```

Literatura

- Listy dostępu routerów Cisco –
  Przewodnik specjalistyczny
  G. Held
  K. Hundley
- www.PCWC.pl
- www.iana.org/assignments/port-numbers